

A graphic featuring a blue laptop with the text "OWASP TOP 10" on its screen. To the left of the laptop is a yellow padlock icon, and to the right is a red octagonal warning sign with a white exclamation mark. Above the laptop is a blue shield icon with a white fly in the center. The background is dark blue with a faint world map and circuit-like patterns.

- **CWE – Common Weakness Enumeration**
 - List of types (categories) of errors in software or hardware.
 - Does not describe a specific case in a given application (such as CVE), but a general error mechanism.
 - Classification of errors to understand why they occur and how to avoid them in the programming phase.
 - Format:
 - CWE NUMBER (e.g. CWE-89 is "SQL Injection" and CWE-79 is "Cross-site Scripting").
 - For programmers and software architects, so they know

- **CVE – Common Vulnerabilities and Exposures**
 - A catalogue (list) of specific, publicly disclosed security vulnerabilities in software or hardware.
 - Assigning a unique identifier to a specific bug so that everyone in the world knows what they are talking about.
 - Format:
CVE-YEAR-NUMBER (e.g. CVE-2021-44228 is the famous Log4Shell vulnerability).
 - For system administrators and security specialists who need to know if their systems are vulnerable to a specific attack.

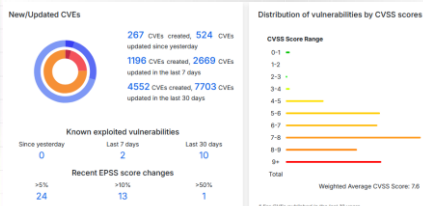
Vulnerability

Published in: 2026 January

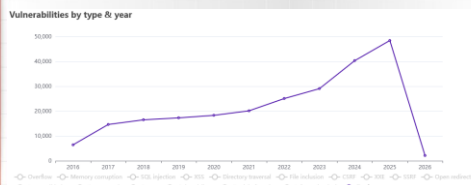
CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9 In CISA KEV Catalog

Sort Results By: Publish Date Update Date CVE Number CVE Number TS CVSS Score EPSS Score

Page 1 of 1

[illegible]

* For CMEs published in the last 30 years

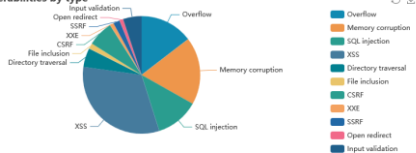


Vulnerabilities

Vulnerabilities by impact types

Year Code Execution Bypass Privilege Escalation Denial of Service Information Leak

Vulnerabilities by type



Total 21978 6690 10182 23456 10432

For selected app/vendor/ ...

Adobe > Acrobat Reader : Product details, threats and statistics

Versions Vulnerabilities (1076) Product Dashboard CVSS Report Metasploit Modules

Log in to view product risk score details

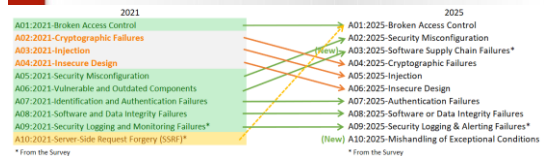
Vulnerabilities by types/categories

Year	Overflow	Memory Corruption	Sql Injection	XSS	Directory Traversal	File Inclusion	CSRF	XSE	SSRF	Open Redirect	Input Validation
2016	0	18	0	0	0	0	0	0	0	0	0
2017	59	80	0	0	0	0	0	0	0	0	0
2018	1	18	0	0	0	0	0	0	0	0	0
2019	1	4	0	0	0	0	0	0	0	0	0
2020	5	61	0	0	3	0	0	0	0	0	0
2021	10	74	0	0	0	0	0	0	0	0	0
2022	4	36	0	0	2	1	0	0	0	0	0
2023	1	32	0	0	1	0	0	1	0	0	0
2024	0	10	0	0	0	0	0	0	0	0	0
2025	0	10	0	0	0	0	0	0	0	0	0
Total	80	295	0	0	5	1	0	1	0	0	10

What is OWASP?

- OWASP = Open Web Application Security Project
- International application security organization
- Publishes Top 10 every 3-4 years
- Contains the most common and serious threats
- 70% of applications have errors from OWASP Top 10

Open Worldwide Application Security Project OWASP Top Ten 2025



Typical Web Application Architecture

- Layer Overview:
 - User
 - ↓ HTTP/HTTPS
 - Frontend (Browser / SPA)
 - ↓ REST / GraphQL
 - Backend (API)
 - ↓ SQL / NoSQL
 - Database
- Each layer = potential attack vector

Attack Surface (Attack Surface)

- HTTP Parameters
- Headers
- Cookies
- Session Tokens
- External Libraries
- Authentication Mechanisms

OWASP TOP 10

- Each point in OWASP TOP 10 consists of several parts:
 - General description of the risk, usually describing example attacks.
 - Methods of protection against the risk.
 - Example attack scenarios - being more technical than the examples above.
 - References - usually to other OWASP sources, though not always.
 - List of CWEs - references to the list of errors from CWE (Common Weakness Enumeration) that make up a given point in OWASP TOP 10.



OWASP Top 10 2025 A01: Broken Access Control

- Access control errors.
 - The point concerns **all kinds of errors** where an attacker gains access to a resource/record/service/component/functionality to which they should not be authorized.
- By access we mean here **both reading and modification/writing or deletion**.

Wielkopolskie Center for Occupational Medicine - by changing the ID number in the browser, it was possible to see the test results of other patients.

OWASP Top 10 2025 A01: Broken Access Control

- According to OWASP research, **over 94% of** tested applications had some form of broken access control.
- This is the most common vulnerability in modern web applications.
- Automated tools (SAST/DAST)** have difficulties detecting these errors because they require understanding of **the application's business context**.
- Effects include unauthorized access to data, modification or deletion of resources, and even takeover of full administrative control over the system.

OWASP Top 10 2025 A01: Broken Access Control

```
Account getAccount(@PathVariable Long id) {
    accountRepository.findById(id);
}
```

The controller simply returns data based on the ID from the URL. Any logged-in user can retrieve any account.

```
Account getAccount(@PathVariable Long id, Principal user) {
    Account acc = accountRepository.findById(id);

    if (!acc.getOwner().equals(user.getName())) {
        throw new AccessDeniedException();
    }

    return acc;
}
```

The application verifies whether the resource requested by ID actually belongs to the user making the request.

OWASP Top 10 2025 A01: Broken Access Control Privilege Escalation

Horizontal Escalation

- User gains access to resources of another user with the same privilege level.
- Example: IDOR (changing ID in URL).

Vertical Escalation

- User gains access to functions or data intended for users with higher privileges.
- Example: Manipulating the role=admin parameter in a POST request.

Mitigation Strategies

1. Deny by Default

Block access by default. Make exceptions only for specific, authorized roles (Fail Secure).

2. Principle of Least Privilege

User (and process) should have only as many privileges as are absolutely necessary to perform the task.

3. Server-Side Enforcement

Never rely on hiding buttons in the UI. Every API request must be verified on the backend.

Cross Site Request Forgery

CSRF

- This is forcing the victim's browser to perform a certain unauthorized action.
- This is an attack on the web browser, not the server part of the web application;
- For the server, requests resulting from the attack are completely legal communication from the user's browser.
- CSRF should not be confused with a Man-in-The-Browser attack,
 - the attacker can also influence the browser's operation, but this involves prior installation of malware in the victim's system. In the case of CSRF, neither the system nor the victim's browser are permanently modified in any way.
 - Simply a certain property of web architecture and web browsers is exploited.

CSRF

- Basic CSRF: attacking site uses login cookie
- Goal: force user to perform some action on a website without their knowledge
 - Trick the browser into doing it
 - Main idea: Make a user logged into a given site send a request that will have permanent effects.

CSRF

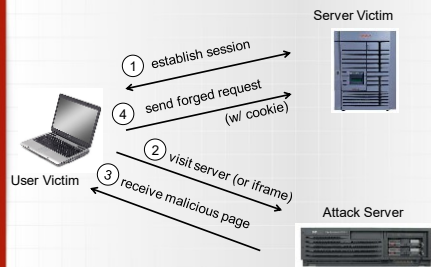
- Session Management and Trust Relationships
- Basic CSRF: attacking site uses login cookie
- CSRF defense based on stronger session management
 - Secret token embedded in page
 - Validation of referrer (better: origin header)
 - Custom headers

CSRF

CSRF Attack Flow (step by step)

1. User logs into application (e.g., bank, admin panel).
2. Browser saves session cookie.
3. User visits malicious attacker's site.
4. Attacker's site sends hidden HTTP request to victim:
 - form,
 - image,
 - JavaScript.
5. Browser automatically attaches session cookies.
6. Server:
 - does not distinguish between legitimate and fake request,

Basic CSRF



Q: How long are you logged into Gmail? Facebook? ...

Cross Site Request Forgery (CSRF)

- Example:
 - User logs into bank.com
 - Session cookie remains in browser state
 - User visits another site containing:


```
<form name=F action=http://bank.com/BillPay.php>
<input name=recipient value=badguy> ...
<script> document.F.submit(); </script>
```
 - Browser sends user's authorization cookie with request
 - Transaction will be executed
- Problem:
 - cookie auth is insufficient when side effects occur

Cross Site Request Forgery (CSRF)

- Cookies for bank.com are automatically sent as HTTP headers with every HTTP request to bank.com.
- The victim does not have to directly visit the page, but their browser only needs to send an HTTP request.
- Essentially, the browser is "confused"
The "confused proxy" attack

CSRF - Mitigations

- The Referer request header contains the address of the previous web page from which a link to the currently requested page was followed. The header allows servers to identify where people are visiting from.
- https://bank.com → https://bank.com ✓
- https://attacker.com → https://bank.com ✗
- [redacted] → https://bank.com ?

Referer Privacy Problems

- Referer can reveal private information
`http://intranet.corp.apple.com/projects/iphone/competitors.html`
- Common sources of blocking:
 - Stripping by organization network
 - Stripping by local computer
 - Stripped przez browser for transit HTTPS -> HTTP
 - User preferences in browser
 - Buggy user programs
- Site cannot afford to block these users

CSRF - Recommendations

- Login CSRF
 - strict Referer/Origin header validation
 - Login forms are usually transmitted via HTTPS, not blocked
- HTTPS pages, such as bank pages
 - Use strict Referer/Origin validation to prevent CSRF
- Others
 - Use a framework that correctly implements the secret token method
- Origin header
 - Alternative to Referer with fewer privacy issues
 - Sent only for POST, send only necessary data
 - Defence against redirect attacks

OWASP Top 10 2025

A02: Security Misconfiguration

What is Security Misconfiguration?

Definition

Security misconfiguration occurs when systems, applications or cloud infrastructure are deployed with dangerous default settings or incomplete configurations.



Why is this a problem?

The growing complexity of systems (microservices, containers, cloud) makes manual configuration management prone to human error.

OWASP Top 10 2025

A02: Security Misconfiguration

Main Vulnerabilities

Configuration errors in both server and application parts. Below are some typical representatives of this category:

1. Lack of hardening of network services or improperly configured permissions in cloud services,
2. Enabling unnecessary features (e.g., opening unnecessary ports, services, pages, accounts or permissions),
3. Using accounts with default usernames and passwords,
4. Displaying stack traces containing overly detailed information about the application or environment,
5. Improper configuration of application servers, frameworks (e.g., Struts, Spring, ASP.NET), libraries and databases,
6. Not sending so-called security headers

OWASP Top 10 2025

A02: Security Misconfiguration

Attack Scenario: Default Credentials

1. Attack vector:

Attacker scans the network for admin panels of known services (e.g., application servers, routers, databases).

2. Exploitation:

Finding an unsecured console, the attacker logs in using default credentials (e.g., 'admin' / 'password') that were not changed during deployment.

3. Effect:

Complete takeover of system control.

OWASP Top 10 2025

A02: Security Misconfiguration

Scenario: Information Leak

Directory Listing	System Errors
• Server has directory listing enabled. Attacker accesses the URL and sees the file structure. • Result: Download of compiled Java classes or configuration files, allowing reverse engineering of the application.	• Application throws an unhandled exception. Instead of a generic message, the user sees the full Stack Trace. • Result: Disclosure of library versions, system paths, and backend logic, facilitating targeting of known vulnerabilities (CVE).

OWASP Top 10 2025

A02: Security Misconfiguration

Mitigation Strategies: Processes

- 🔧 **Automation:** Implement a repeatable hardening process for all environments (Dev, QA, Prod). Infrastructure as Code (IaC).
- 🗑️ **Minimalism:** Remove unnecessary features, sample applications and documentation. "If you don't use it, remove it".
- 🔍 **Verification:** Automated scanning of settings effectiveness in all environments after each deployment.
- 🔄 **Patch Management:** Regular review and update of configuration and patching of components.